Cloud Security Risk Assessment and GRC Simulation (Microsoft Azure)

By
Abubakar Yusuf
(SOC Analyst)

Executive Summary

This report documents the results of a cloud security risk assessment conducted on a single Azure-hosted virtual machine from a Governance, Risk, and Compliance (GRC) perspective. The purpose of the assessment is to identify critical assets, evaluate realistic threat scenarios, assess vulnerabilities, quantify risk, and recommend security controls aligned with recognized industry frameworks.
The assessment identified multiple mediums to high risks, primarily related to exposed remote access, lack of multi-factor authentication, default operating system hardening, and limited centralized monitoring. While no active exploitation was observed during the assessment, these findings reflect common cloud misconfigurations that could be leveraged by attackers if left unaddressed.

Scope and Environment

Assessment Scope:

- Single Azure Virtual Machine deployed.
- No additional cloud services or application included
- Assessment performed from a GRC (Non-exploitative) perspective.

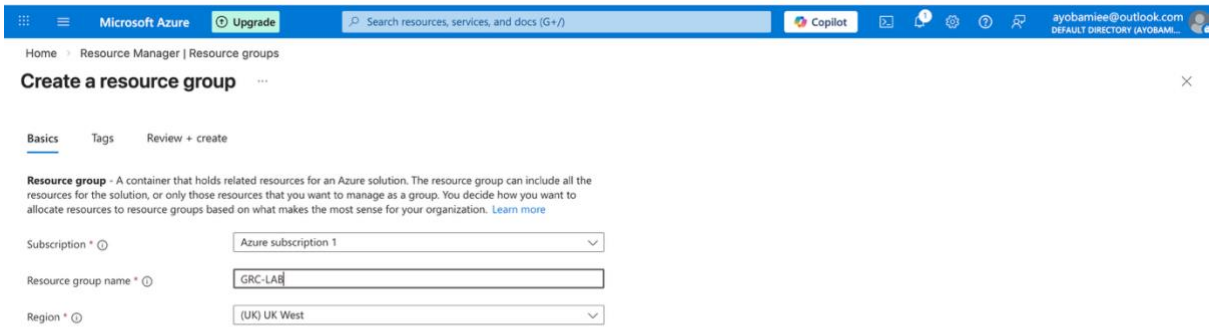
Environment Details

Items	Descriptions
Cloud Provider	Microsoft Azure
Resource group	GRC-LAB
Virtual machine name	GRC-WIN-VM01
Operating System	Windows Server 2022 Datacentre
Access Method	Remote desktop protocol (RDP)
Public exposure	Public IP (enabled)
Administrative Account	Admin090623

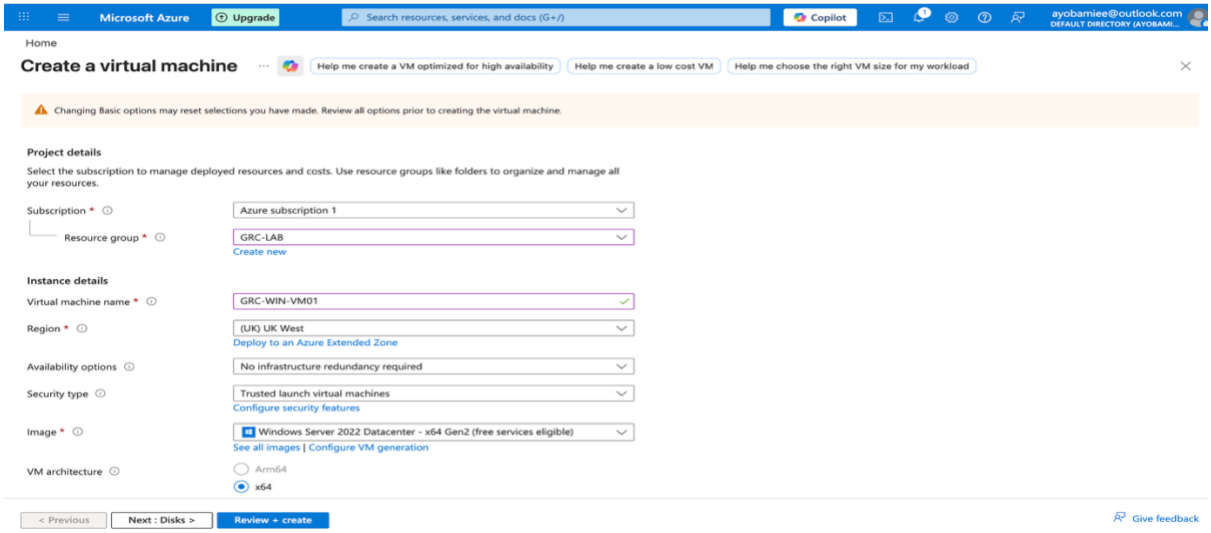
Setting up the Environment

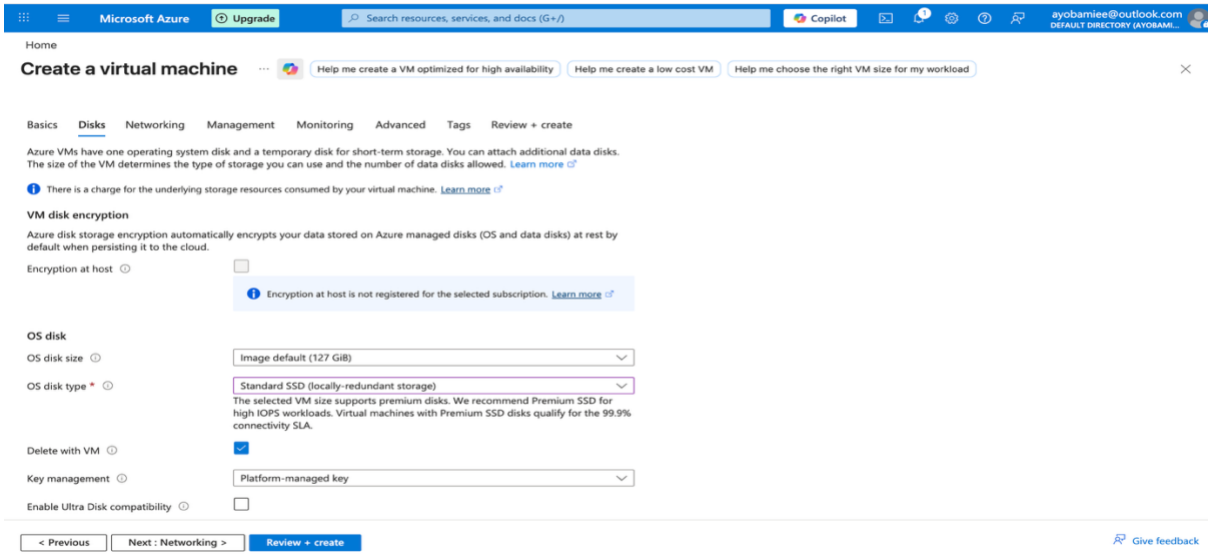
Lab environment set-up:

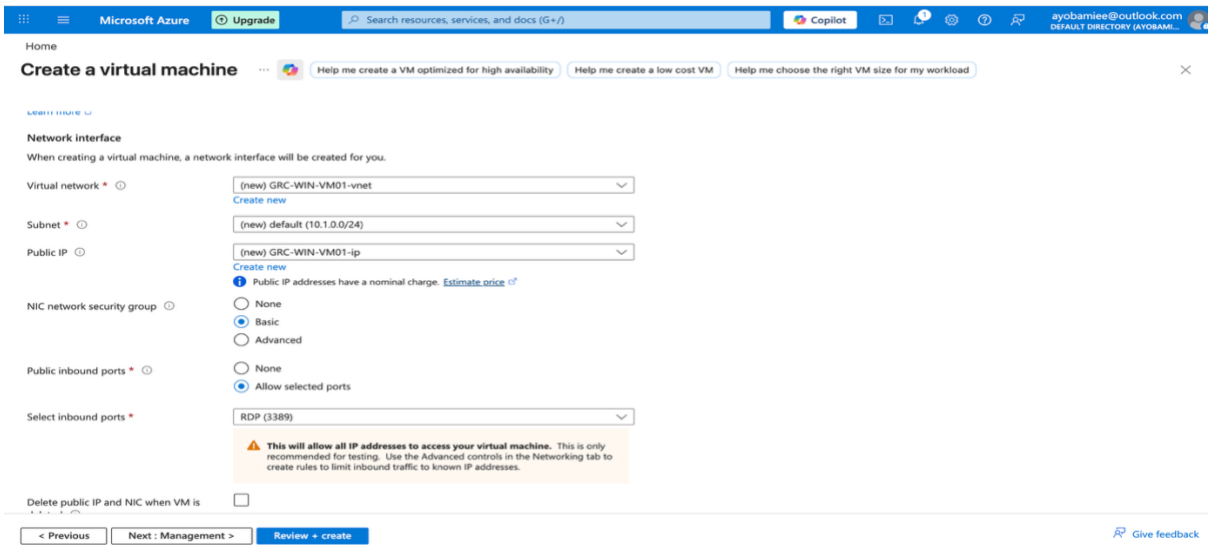
Set up an Azure account and create a resource group named (GRC-LAB)

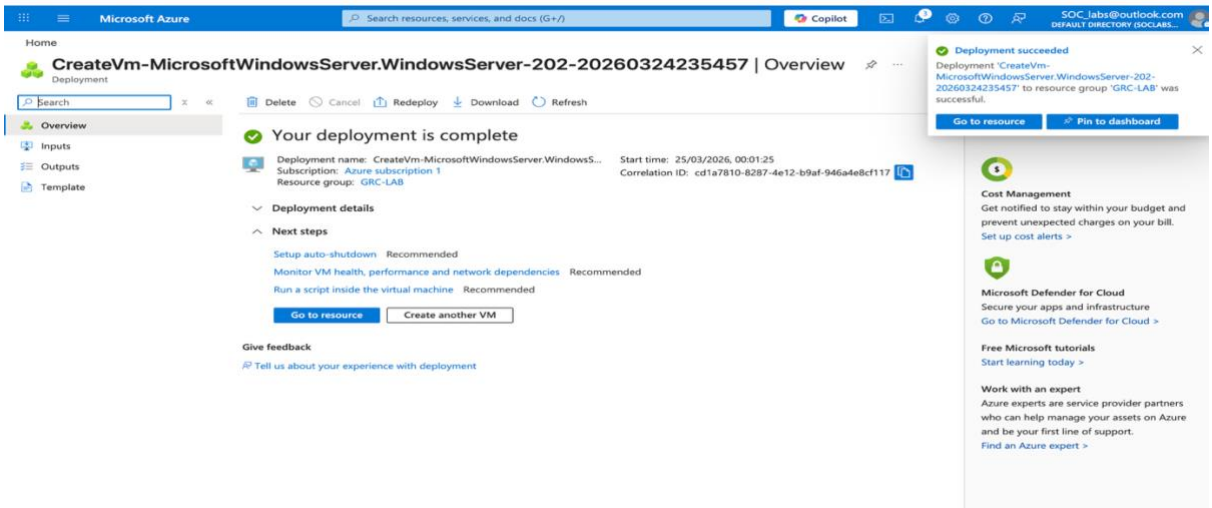


Create a Virtual machine named (GRC-WIN-VM01) and ensure it is resourced under resource group (GRC-LAB), allocate the disk-type and inbound port is set at RDP

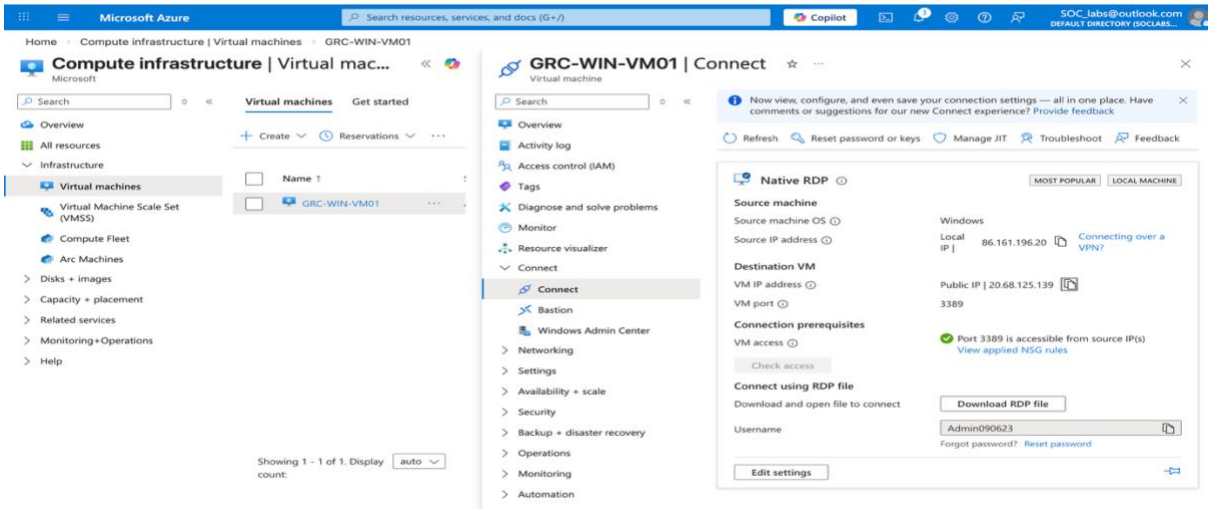








GRC-WIN-VM01 is deployment is complete.



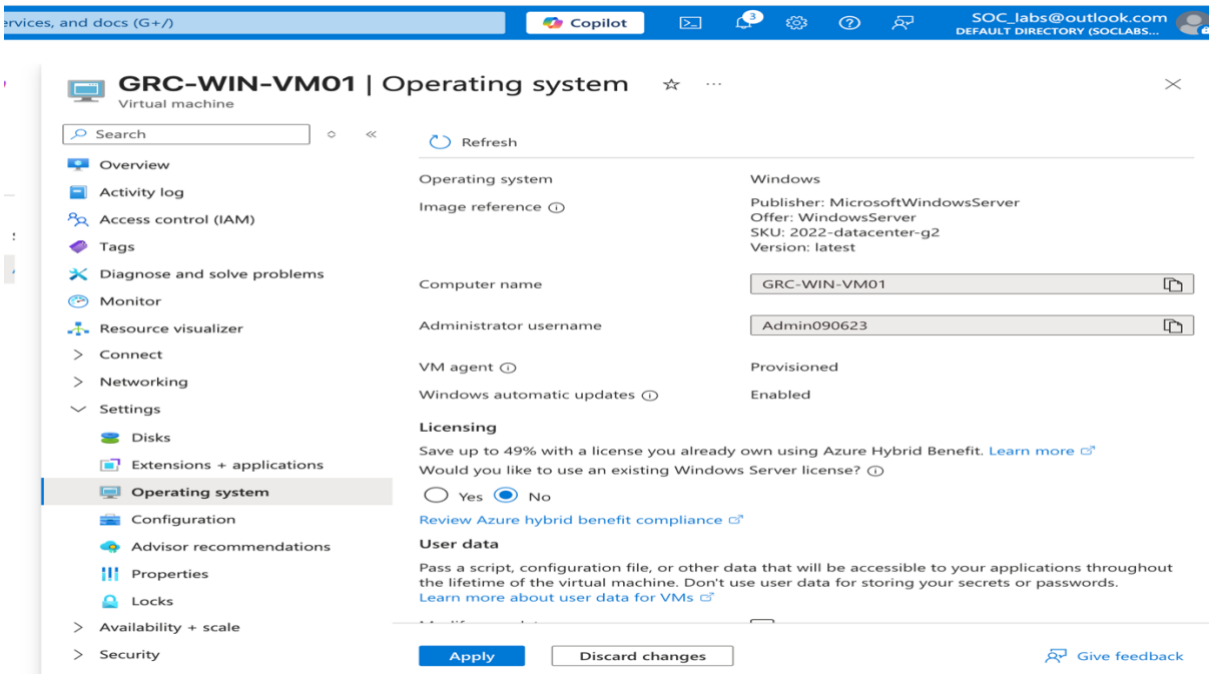
Identify Assets, Threats and vulnerabilities

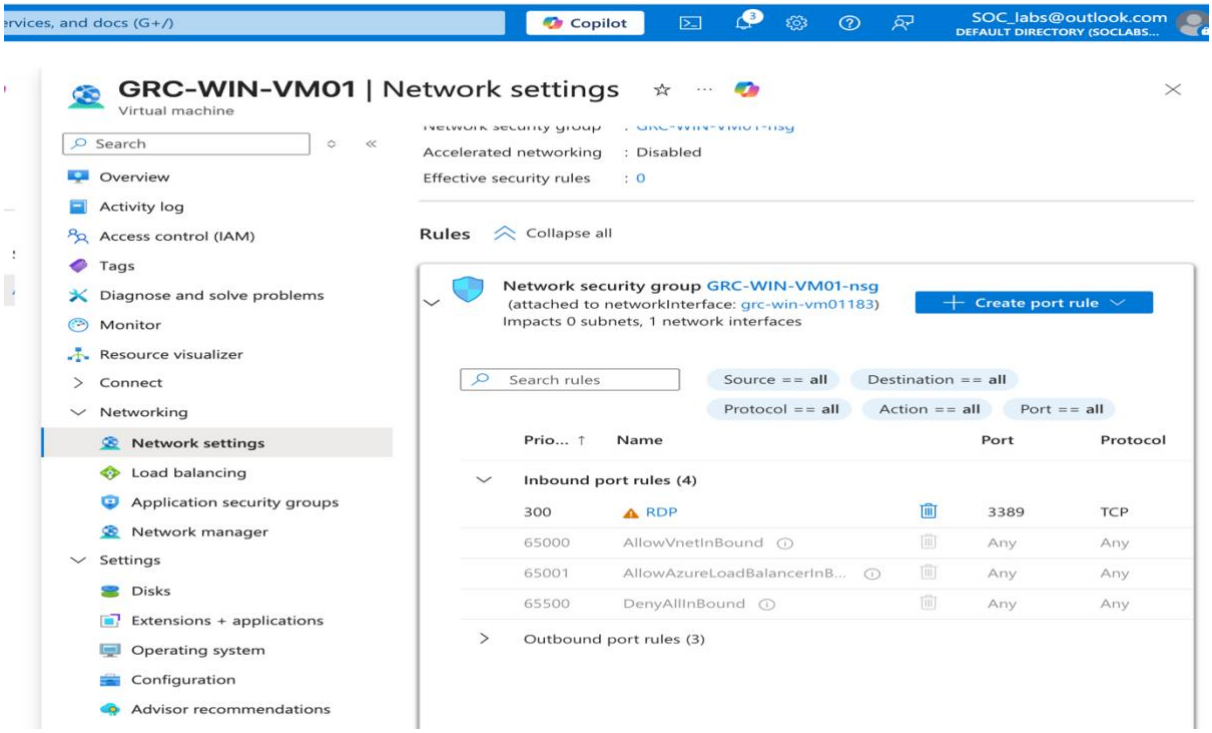
In other for us to map about the right things, we need to ask these questions:

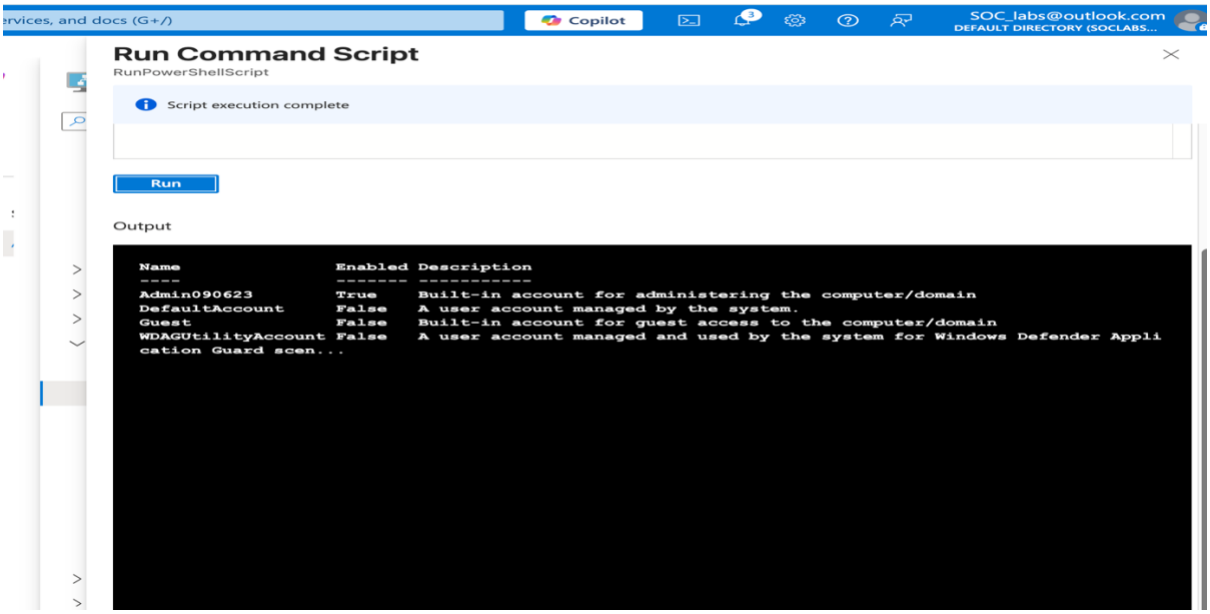
1. What are we protecting (Assets)
2. What could go wrong (Threats)
3. Why the threat could be exploited (Vulnerabilities)

Let start by identifying the assets in our environment (What would hurt if compromised)

- Confirm the operating system running on the VM for asset inventory and risk classification.
- Confirm network settings to Identify externally accessible services that increases the attack surface.
- Confirm and identify privileged accounts with elevated access to the system.
- Determine whether the VM is accessible from the internet.


ervices, and docs (G+/)
Copilot
SOC_labs@outlook.com
DEFAULT DIRECTORY (SOCLABS...
GRC-WIN-VM01 | Operating system
Virtual machine
Search
Overview
Activity log
Access control (IAM)
Tags
Diagnose and solve problems
Monitor
Resource visualizer
Connect
Networking
Settings
Disks
Extensions + applications
Operating system
Configuration
Advisor recommendations
Properties
Locks
Availability + scale
Security
Refresh
Operating system
Windows
Image reference
Publisher: MicrosoftWindowsServer
Offer: WindowsServer
SKU: 2022-datacenter-g2
Version: latest
Computer name
GRC-WIN-VM01
Administrator username
Admin090623
VM agent
Provisioned
Windows automatic updates
Enabled
Licensing
Save up to 49% with a license you already own using Azure Hybrid Benefit. Learn more
Would you like to use an existing Windows Server license?
Yes
No
Review Azure hybrid benefit compliance
User data
Pass a script, configuration file, or other data that will be accessible to your applications throughout the lifetime of the virtual machine. Don't use user data for storing your secrets or passwords.
Learn more about user data for VMs
Apply
Discard changes
Give feedback


ervices, and docs (G+/)
Copilot
SOC_labs@outlook.com
DEFAULT DIRECTORY (SOCLABS...
GRC-WIN-VM01 | Network settings
Virtual machine
Search
Overview
Activity log
Access control (IAM)
Tags
Diagnose and solve problems
Monitor
Resource visualizer
Connect
Networking
Network settings
Load balancing
Application security groups
Network manager
Settings
Disks
Extensions + applications
Operating system
Configuration
Advisor recommendations
Accelerated networking : Disabled
Effective security rules : 0
Rules
Collapse all
Network security group GRC-WIN-VM01-nsg
(attached to networkInterface: grc-win-vm01183)
Impacts 0 subnets, 1 network interfaces
Create port rule
Search rules
Source == all
Destination == all
Protocol == all
Action == all
Port == all
Prio... ↑
Name
Port
Protocol
Inbound port rules (4)
300
RDP
3389
TCP
65000
AllowVnetInBound
Any
Any
65001
AllowAzureLoadBalancerInB...
Any
Any
65500
DenyAllInBound
Any
Any
Outbound port rules (3)



Think beyond hardware, Asset can include anything attackers want or can abuse. If it holds value, grants access, or provides privilege, it's an asset. Assets are not limited to servers, accounts, access pathways, and cloud permissions are also considered assets.

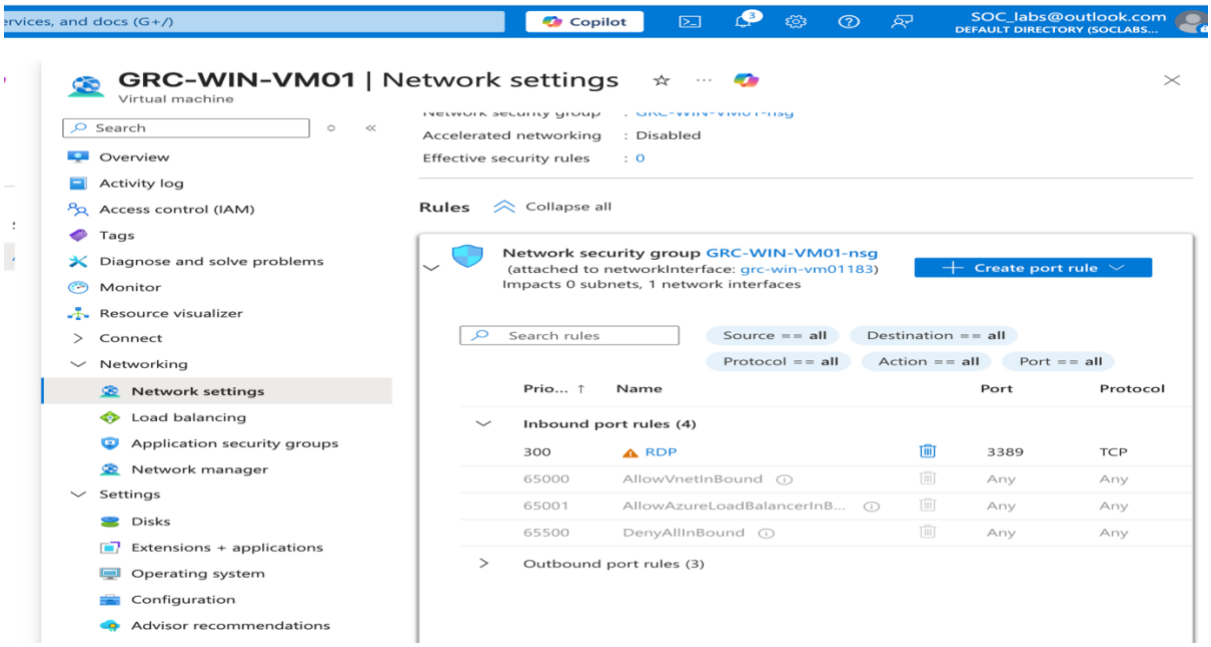
Asset Category	Asset	Reason
Compute	Azure VM (GRC-WIN-VM01)	To host data and services
Network & Access method	Public IP, NSG rules and RDP port	Entry point for attackers
Identity	Admin account	Full system control
Operating system	Window services	Vulnerable if unpatched
Data	Security logs	

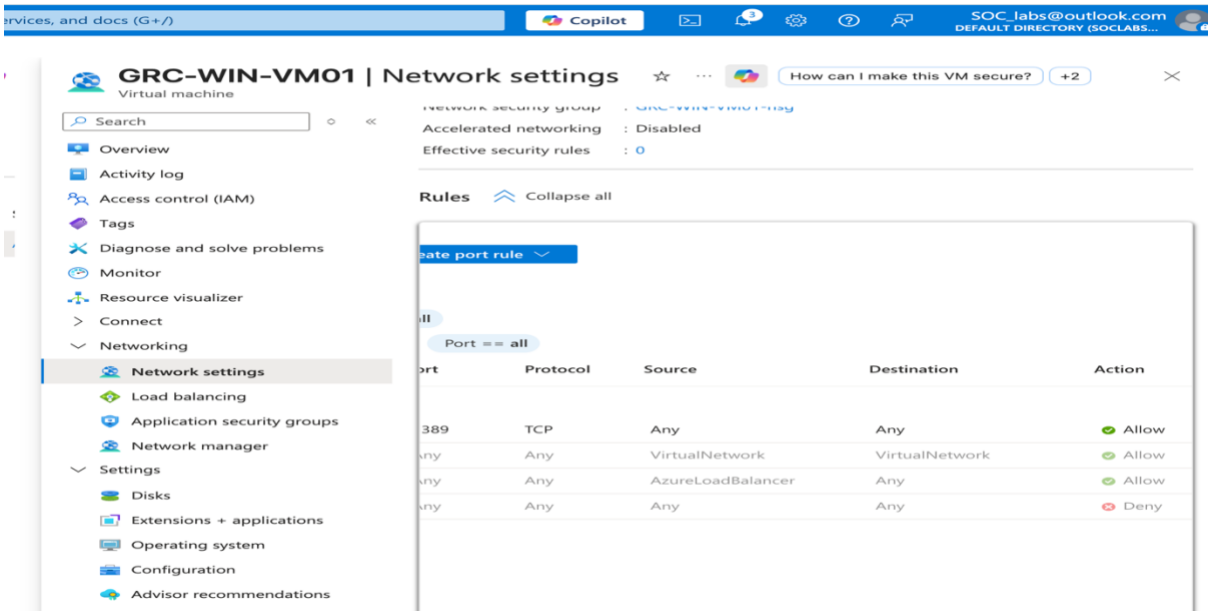
Threats Identification in the environment

Asset	Threat	Threat Actor
Public IP/RDP	Brute force Attack/credential surfing	External attacker /Botnets
Azure Account	Unauthorize configuration changes	Insider/attacker
Admin account	Privilege abuse /Password Compromise	Insider/Attacker
Operating System	Exploitation of known Vulnerabilities	Attacker
Logs	Undetected malicious activity	Attacker

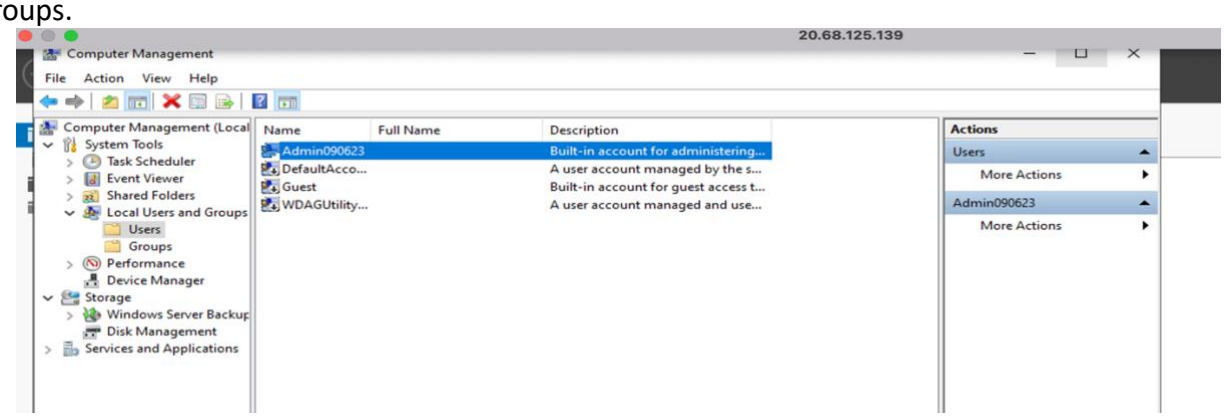
Vulnerability Identification in the Environment

It is important to distinguish that vulnerabilities represent inherent weaknesses within a system, rather than active threats or attacks. Within the network configuration of the environment, the Network Security Group (NSG) is associated with either the network interface or subnet. Analysis of the inbound security rules indicates that Remote Desktop Protocol (RDP) traffic (port 3389) is permitted, with the source configured as **"Any"** and the action set to **"Allow."** This configuration introduces a significant security weakness by exposing the system to the public internet. As a result, it increases the likelihood of unauthorized access attempts, including brute-force attacks and credential stuffing attacks, thereby elevating the overall risk posture of the environment.



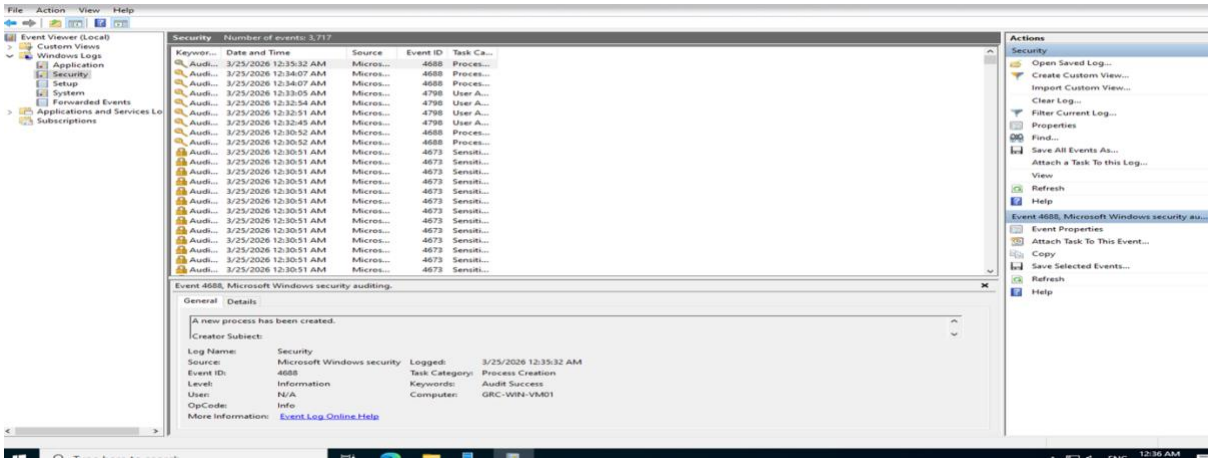


Check Authentication Method:
In the GRC-WIN-VM01, you access the computer management then check the local users and groups.

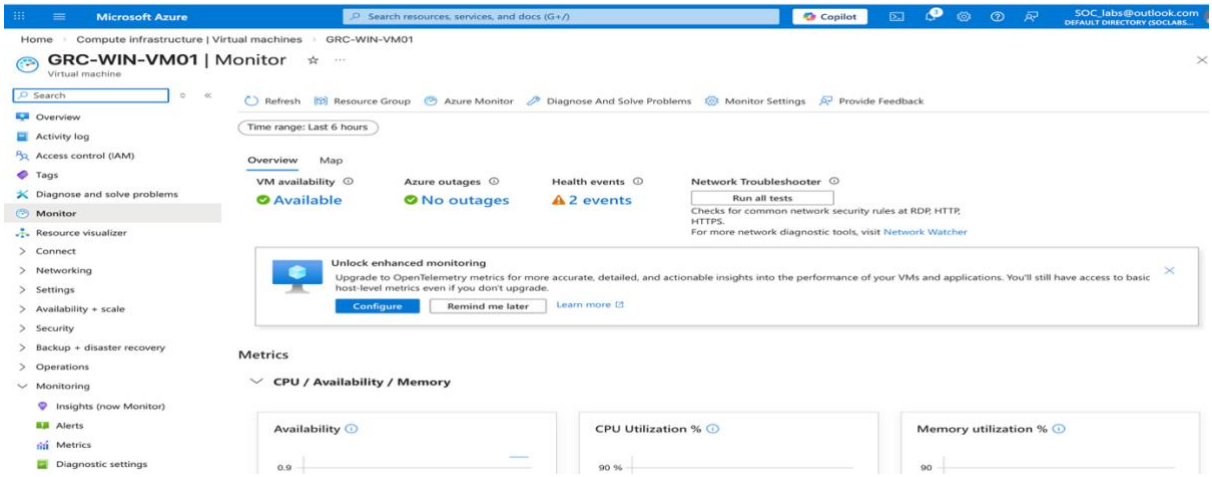


This confirms “Admin090623’ is a member of the administrative group.

Window security logging on the GRC-WIN-VM01
In the VM, you need to ensure that logs are being generated via the event viewer.



Azure monitoring: If enabled, metrics and basic performance are visible and if not enable, Azure will prompt you.



This assessment assumes that the virtual machine is using a standard Windows Server 2022 setup with no extra security measures beyond what Azure and the operating system provide by default. There are no custom Group Policies, CIS benchmarks, or security standards in place. Windows Defender and Windows Firewall are turned on with their default settings, and no additional host-based security measures have been added unless specified.

Asset	Vulnerability	Why it matters
GRC-WIN-VM01	Public RDP exposure	Entry point for attackers
Authentication	No MFA	Password Compromise
Operating System	Default OS Configuration	Common exploit target
Monitoring (detection & response)	No SIEM integration	Attacks may go unnoticed
Identity	Single Admin account	No accountability

It is not necessary to actively exploit a weakness for it to be classified as a vulnerability. Any condition that can be potentially misused or leveraged by a threat actor constitutes a vulnerability. Therefore, the existence of a vulnerability does not depend on demonstrated exploitation.

Risk Scoring Framework

Component	Description	Scoring
Likelihood	Probability that a threat will exploit a vulnerability	1 = Rare, 2 = Unlikely, 3 = Possible, 4 = Likely, 5 = Almost Certain
Impact	Consequence of a successful exploit on the asset	1 = Insignificant, 2 = Minor, 3 = Moderate, 4 = Major, 5 = Critical
Risk score	Quantified risk = Likelihood × Impact	1–25 (1 = lowest risk, 25 = highest risk)

Risk level Classification

Risk Score	Level	Action
0-1	Low	Acceptable risk, Monitor
2-3	Medium	Mitigation recommended
4	High	Immediate mitigation advised
5	Critical	Urgent remediation

Quantifying risk for our Azure GRC-WIN-VM01 assessment

Asset	Vulnerability	Threat	Likelihood	Impact	Risk score	Risk level
GRC-WIN-VM01	Public RDP exposure	Brute force/Credential surfing	4	4	16	Critical
Admin account	Single account, No MFA	Privilege abuse/password compromise	3	5	15	Critical
Operating System	Default OS Configuration	Exploitation of Known Vulnerabilities	3	4	12	High
Security Logs	No Siem/centralised monitoring	Undetected malicious activity	3	3	9	Medium
Azure account	Unrestricted privilege	Unauthorized configuration changes	2	5	10	Medium

Why does this matter: It matters because quantifying risk turns technical vulnerabilities into clear, actionable priorities, helps allocate resources efficiently, aligns with compliance requirements, and allows management to make informed decisions based on objective data rather than subjective judgment.

Mapping security Control to policies and frameworks

Risk	Security control	Control type	Compliance
Public RDP exposure	- Restrict RDP access via NSG to specific IPs - VPN gateway for remote access	Preventive	ISO 27001 A.9.4 (Access Control) CIS Control 12.3 (Secure Remote Access)
Exploitation of known vulnerabilities	- Regular patch management - Enable Windows Update automation - Use vulnerability scanning tools	Corrective	ISO 27001 A.12.6 (Technical Vulnerability Management) CIS Control 7 (Continuous Vulnerability Management)

No SIEM integration	- Enable centralized logging - Configure alerting for suspicious events - Retain logs per regulatory requirements	Detective	ISO 27001 A.12.4 (Logging & Monitoring) NIST 800-53 AU-2 (Audit Events)
Unauthorised changes/privilege misuse	- Implement role-based access control (RBAC) - Enforce least privilege principle - Enable activity logs & alerting	Preventive	ISO 27001 A.6.1 (Organization of Information Security) NIST 800-53 AC-6 (Least Privilege)
Single account, no MFA	- Implement Multi-Factor Authentication (MFA) - Create individual privileged accounts - Enable logging and alerting for admin actions	Preventive	ISO 27001 A.9.2 (User Access Management) NIST 800-53 IA-2 (Identification & Authentication)
Default OS Configuration	- Apply OS hardening (CIS Benchmarks) - Disable unnecessary services - Enable Windows Defender & Firewall	Preventive	NIST 800-53 CM-6 (Configuration Management) CIS Control 5 (Secure Configuration)

Mitigation Recommendations

For this project, the general recommended mitigation actions are:

1. Restrict and secure access: Limit remote access to the VM, implement MFA, and follow the principle of least privilege for all accounts.
2. Harden the system: Apply OS hardening, patch regularly, and disable unnecessary services and ports.
3. Enable monitoring and logging: Centralize logs, configure alerts for suspicious activity, and regularly review security events.
4. Manage vulnerabilities proactively: Conduct regular vulnerability scans and remediate findings promptly.
5. Enforce cloud governance: Use role-based access control, audit configuration changes, and implement policies aligned with compliance frameworks.
6. Backup and recovery planning: Maintain backups of critical data and VM images and test recovery procedures.